Threat Actors — SY0-701 Study Notes (Section 03)

Maps to exam objectives: 2.1 (Motivations, attributes & types of threat actors, insider threats, shadow IT), 2.2 (Threat vectors & attack surfaces), 1.2 (Deception & disruption technologies).

The Threats/Vulnerabilities domain is one of the heaviest-weighted on SY0-701 — expect several questions straight from this section, usually as **compare/contrast** ("Which actor is MOST likely…") or scenario-based ("An employee did X — what is this called?").

1. Threat Actor Motivations (Obj 2.1)

The 10 motivations — learn this list cold; matching questions love it:

Motivation	Who / How it shows up
Data exfiltration	Unauthorized transfer of data out of the org. Targets: intellectual property, PII, trade secrets.
Blackmail	Threatening to expose data unless paid. Forms: ransomware, doxxing, sextortion. Payment usually demanded in **cryptocurrency (Bitcoin)**.
Espionage	Spying to steal secrets — mostly **nation-state** actors.
Service disruption	Taking systems offline — typically **DDoS**. (Example cited: GitHub hit by a massive DDoS in 2018.)
Financial gain	The #1 driver for cybercrime — ransomware, banking trojans, fraud.
Philosophical/political beliefs	**Hacktivism** — hacking to advance a cause.
Ethical reasons	The "good guys": penetration testers, bug bounty hunters — authorized.
Revenge	Disgruntled or fired employees striking back at the org.
Disruption/chaos	"Watch the world burn" — unauthorized hackers who just want to cause mayhem.
War	Cyber warfare conducted by nation-states against other nations.

Exam trap — Intent vs. Motivation:

- **Motivation** = the underlying reason (why: money, ideology, revenge).
- **Intent** = the desired outcome of the specific action (what: steal data, disrupt service).
- CompTIA loves a stem that describes both and asks for one. Read carefully.

2. Threat Actor Attributes (Obj 2.1)

Three attributes classify any threat actor:

1. **Internal vs. External** — based on the actor's **relationship to the targeted organization**, not their physical location.
   - **Internal:** employees, contractors, business associates — they have legitimate access and use it in an unauthorized way. Dangerous because of intimate knowledge of infrastructure and vulnerabilities.

  - **External:** outsiders (cyber criminals, hacktivists, competitors, state-sponsored) with **no authorized access** — must use malware or social engineering to get in.
2. **Resources & Funding** — tools, skills, and personnel available. Drives the scale, frequency, and sophistication of attacks. A lone hacker has a PC and personal skills; a nation-state has budgets, teams, and advanced tooling.
3. **Sophistication & Capability** — technical skill, tool complexity, and ability to evade detection. Rated **low → high**:
  - **Low:** widely available tools, common malware, phishing. Bottom of the scale = **script kiddies**.
  - **High:** custom malware, **zero-day exploits**, advanced evasion. Nation-states and **APT groups** live here — can dwell undetected in well-defended networks for extended periods.

3. Types of Threat Actors (Obj 2.1)

Comparison table — memorize this, it is THE exam pattern

Actor	Motivation	Funding/Resources	Sophistication	Signature traits
Unskilled attacker (script kiddie)	Recognition, thrill, curiosity	Very low	Low	Uses **other people's tools** (e.g., **LOIC** to DDoS); opportunistic, not targeted; attacks easy/weak targets; sheer numbers make them a real threat
Hacktivist	Ideology — political/social cause	Varies (often self-funded)	Fairly **high**	Defacement ("electronic graffiti" = vandalism), DDoS, **doxxing**, data leaks. Groups: **Anonymous** (Operation Payback, 2010, vs MPAA/RIAA), **LulzSec** (50 Days of Lulz, 2011 — Sony, CIA, FBI)
Organized crime	**Financial gain — almost always**	High, well-structured	Very high	Roles/chain of command like the mafia; custom malware, ransomware, sophisticated phishing; exploits cryptocurrency & dark web; **transnational** = hard to prosecute; may act as **"hired guns"/mercenaries** for governments. Examples: **FIN7** (retail & hospitality phishing), **Carbanak** (>$1B from banks; forced ATMs to dispense cash)

Actor	Motivation	Funding/Resources	Sophistication	Signature traits
Nation-state	Long-term **strategic goals** — intelligence, infrastructure disruption, influencing political processes, IP theft	State-backed, essentially unlimited	Highest	Part of intelligence/military or **proxies** for **plausible deniability**; custom malware + zero-days + APTs; **false flag attacks**; mostly NOT financial — **except North Korea** (banks, crypto exchanges). Examples: **Stuxnet** (US/Israel attributed; destroyed Iranian nuclear centrifuges via USB across an air gap, using Windows zero-days), 2016 US election interference
Insider	Financial gain, revenge — or unintentional	N/A (already inside)	Varies with role + skill	Has legitimate access; knows layout/processes; forms: data theft, sabotage, privilege misuse, planting backdoors; also **careless/untrained users** (phishing clickers). Examples: **Edward Snowden** (NSA contractor, 2013), **Twitter 2020** Bitcoin scam aided by insiders

Traps:

- **Script kiddie ≠ hacktivist**: both may deface sites, but script kiddies want notoriety, hacktivists want change. The course explicitly says script kiddies are "less likely to be motivated by financial gain or political ideologies."
- **Hacktivist vs nation-state**: both attack governments, but hacktivists = ideology/attention, nation-states = strategy/espionage and they have state resources.
- **Organized crime may act politically — but only for money** ("hired guns").
- **APT ≠ nation-state, strictly**: APT used to be synonymous with nation-state, but sophisticated organized crime groups are now also called APTs. **APT = a prolonged, targeted attack where the intruder stays undetected for an extended period** to steal data or monitor activity — not to cause immediate damage.

Insider threats — extra detail

- Capability = f(role/access, individual skill). A skilled user with low privileges can out-damage an unskilled admin.
- Can **facilitate external attacks**: install malware, create backdoors.

- Mitigation: **Zero Trust architecture, robust access controls, regular audits, security awareness training.**

4. Shadow IT (Obj 2.1)

- **Definition:** use of IT systems, devices, software, applications, or services **without explicit organizational approval**. Also called **stealth IT** or **client IT**.
- Managed outside/without the knowledge of the IT department.
- **Why it exists:** (1) security posture set too high or too complex for business to function (course example: 45 days to get a second monitor → employee buys their own); (2) desire for efficiency/convenience (browser plugins, unsanctioned apps); (3) cloud services + **BYOD** trend.
- **Forms:** personal devices for work, unapproved software, personal cloud storage (Dropbox/Google Drive) for work files, personal peripherals (USB drives, external disks, network adapters).
- **Risks:** the IT dept **cannot secure what it doesn't know exists** — unknown security posture, no lifecycle management → data breaches, regulatory non-compliance, system disruption, lack of standardization, harder incident troubleshooting.
- Exam angle: an employee using Dropbox for work docs, or a self-bought monitor/USB stick = shadow IT. A helpdesk-approved tool is not.

5. Threat Vectors & Attack Surfaces (Obj 2.2)

- **Threat vector = the HOW** — the means or pathway an attacker uses to gain unauthorized access or deliver a payload.
- **Attack surface = the WHERE** — all points where an unauthorized user could enter or extract data; the sum of all vulnerabilities and entry points.
- **Shrink the attack surface:** restrict access, remove unnecessary software, disable unused protocols. Email/IM, removable devices, and unsecured networks all expand it.

The six threat vectors

Vector	What it is	Example from course
Message-based	Email, SMS, instant messaging — phishing: impersonating a trusted entity to steal info or deliver malware links/attachments	"Free iPhone, click this link" email
Image-based	Malicious code embedded inside image files, executed when the image loads	**Stegano (2017)**: code hidden in banner-ad pixels, exploited old Internet Explorer, redirected to exploit kit
File-based	Malicious files disguised as legit documents/software — email attachments, file shares, malicious sites	Cracked/pirated game laced with malware
Voice calls (vishing)	Phone calls impersonating trusted entities to extract info	Fake "IRS" calls demanding SSN/payment (real IRS sends letters)

Vector	What it is	Example from course
Removable devices	USB thumb drives, external HDDs/SSDs — technique = **baiting**: leaving infected USBs in parking lots/lobbies; or sneaking in to plug devices in directly	Stuxnet crossing an air gap on USB
Unsecured networks	Wireless, wired, Bluetooth without proper security	Wireless: **evil twin** rogue AP mimics legit Wi-Fi → intercept/modify traffic. Wired: cable tapping, MAC address cloning, VLAN hopping. Bluetooth: **BlueBorne** (take over devices/spread malware/on-path attack — no user interaction) and **BlueSmack** (DoS via oversized L2CAP packets → crash)

Traps: vishing = voice phishing (not video); baiting is the name of the USB technique, not just a generic word; BlueBorne = takeover/RCE, BlueSmack = denial of service.

6. Deception & Disruption Technologies (Obj 1.2)

Purpose: mislead, confuse, and divert attackers from critical assets while detecting them — and learn their **TTPs (tactics, techniques, and procedures)** = the methods and behavior patterns of a specific threat actor/group.

The four "honey" technologies — know the differences exactly

Technology	What it is	Key facts
Honeypot	A **decoy system** mimicking a real system with attractive vulnerabilities	Purpose is **not to block attacks** but to gather info on methods, motives, TTPs. Works against **insider threats** too (detect fraud/snooping). Logs all interactions. Place in a **screened subnet / isolated segment** reachable from the internet
Honeynet	A **network of honeypots** mimicking an entire network (servers, routers, switches)	Used by large orgs/researchers. Logs successful AND unsuccessful attacks. **Double-edged sword**: an attacker can study it and learn how your production systems are configured
Honeyfile	A **decoy file** that looks valuable but contains fake data	Hidden metadata/watermarks/unique identifiers to track if stolen; accessing it triggers an alert; some can enumerate the attacker's network; placed under looser defenses than real sensitive files; can be any file type
Honeytoken	A **piece of data with no legitimate value** that is monitored	Fake user account ("Admin"/"Root"), bogus URL, dummy database record, fabricated credentials. **Any access = likely breach** — great for detecting **insider threats** and data-leak pathways; early-warning of breaches

Trap — honeyfile vs honeytoken: a file (looks like a real document) vs a token (fake credential/record/URL — any use is inherently suspicious). If the stem says "fake database entry that should never be accessed" → honeytoken.

Disruption strategies (less famous, still testable)

- **Bogus DNS entries** — fake DNS records sending attackers to non-existent domains; wastes their time and alerts defenders.
- **Decoy directories** — fake folders/files; unauthorized access raises an alert while attacker thinks they succeeded.
- **Dynamic page generation** — ever-changing content to confuse/slow web crawlers, scrapers, bots.
- **Port triggering** — ports stay closed until a specific **outbound traffic pattern** is detected, then open temporarily; services invisible to port scans but available to legit users.
- **Spoofed fake telemetry** — when a scan is detected, respond with false data (e.g., report Windows 11 while actually running macOS) so exploits are mis-targeted.

Rapid-fire self-test (the facts exams repeat)

1. Motivation vs intent? → Motivation = why; intent = desired outcome of the action.
2. Internal vs external is decided by…? → Relationship to the organization, not location.
3. Three actor attributes? → Internal/external; resources & funding; sophistication & capability.
4. Script kiddie's defining trait? → Uses others' pre-made tools without understanding them.
5. Hacktivist's defining trait? → Hacking for a political/social cause, not money.
6. APT meaning? → Prolonged, targeted intrusion that remains undetected for an extended period (steal/monitor, not immediate damage).
7. False flag attack? → Attack made to look like it came from someone else to mislead attribution (e.g., 2018 Olympics malware mimicking North Korea, actually Russia).
8. Which nation-state hacks for revenue? → North Korea (banks, crypto exchanges).
9. Shadow IT = ? → IT used without explicit organizational approval (aka stealth/client IT).
10. Threat vector vs attack surface? → How (pathway) vs where (sum of entry points).
11. Baiting? → Leaving malware-infected USB drives where targets will find them.
12. Vishing? → Voice-call phishing.
13. BlueBorne vs BlueSmack? → Bluetooth takeover/RCE vs Bluetooth DoS.
14. Honeypot placement? → Screened subnet / isolated segment.
15. Honeytoken example? → Fake admin account / dummy DB record — any access signals a breach.
16. Insider threat mitigation? → Zero Trust, access controls, audits, awareness training.